CAPTURE THE FLAG

Киберучения в формате CTF среди студентов
в области информационной безопасности

Добро пожаловать на наш увлекательный CTF по инфобезу - где знания превращаются в навыки, а загадочные флаги ждут, чтобы их нашли. Не волнуйтесь, если что-то не сразу получается — мы все здесь, чтобы вместе учиться, обмениваться опытом и получать удовольствие от процесса.

Чтобы поддержать бодрость и зарядиться энергией, у нас организован вкусный фуршет с разнообразными вкусняшками. Не забывайте подкрепляться — ведь, как гласит нерушимый хакерский закон, лучший специалист — это тот, кто одновременно может работать быстро и не забывать о перекусе. Так что берите свои тарелки и вдохновляйтесь — впереди много интересного!

Ну что, поехали!

Что нужно сделать:

Ваша задача - найти 2 флага:

1. первый прячется в пользовательской директории;
2. второй – в директории root.

Как всё будет:

Каждой команде достанется своя машины Kali Linux с уникальным IP-адресом.
Данные для входа: логин - kali, пароль - kali.
Всё действие разворачивается именно там.

Один из вас может зайти через RDP (в Windows это «Подключение к удалённому рабочему столу»). Так вы получите доступ к браузеру, терминалу и редактору. Остальные могут подключиться по SSH (но это необязательно) и выполнять только консольные команды — просто вбейте в командную строку **ssh kali@адрес.**

Работать будем через терминал Linux (открывается сочетанием ctrl+alt+t). Можно открывать несколько терминалов для удобства. Браузер и текстовый редактор пригодятся, так что держите их под рукой.

Капитан команды будет в специальном чате с организаторами и ботом для проверки флагов. Нашли флаг – киньте его боту (проверяй, что именно боту, а не в общий чат). Дополнительные вопросы к организаторам кидайте в этот же чат.

Подсказки к заданию:

Флаг первый:

1) Узнать свой IP-адрес можно командой **ip a**. Увидите IPv4, IPv6 и MAC-адрес.

Ваша сеть: **192.168.x.1 - 192.168.x.254**. Это и есть целевая сеть, в ней располагается машина, которую вы взламываете.

2) Для разведки соседних хостов используйте различные утилиты:
- **arp-scan** – быстро сканируем сеть по ARP;
- **netdiscover** – ищем устройства в локалке;

CAPTURE THE FLAG

- **nmap 192.168.x.0/24** – сканируем конкретную сеть (если кажется, что ничего не происходит - просто нажмите пробел, чтобы увидеть прогресс).

3) Заходим в браузере на свой найденный хост по соответствующему адресу и порту, например, **192.168.1.17:80**

Часто полезные штуки спрятаны в директориях сайтов, на которые не ведут никакие ссылки. Чтобы их найти используйте **nikto**.

В выводе увидите DNS-имя сервера и интересную скрытую директорию, которую нужно дописать в адресной строке в браузере и зайти на сервер.

4) Часто сайты не отображаются должным образом из-за несоответствия доменных имён, на которые ведут ссылки этих сайтов. Наш браузер просто не знает таких имён. Необходимо операционной системе дать соответствие доменного имени и IP-адреса, взламываемой машины, в файле hosts.

После правильного отображения скрытого сайта можно погулять по нему в поиске интересных ссылок.

5) Находим админ-панель скрытого сайта. Похоже, сайт написан на WordPress? Отлично! Пробуем подобрать логины через утилиту wpscan. Используем команду:

wpscan --url http://адрес_машины/скрытая_директория/ --enumerate u

6) Теперь, когда у нас есть учетная запись, попробуем подобрать пароль с помощью словаря, предварительно разархивировав его:

wpscan --url http://адрес_машины/скрытая_директория/ --usernames логин --passwords /usr/share/wordlists/rockyou.txt

С логином и паролем попробуем зайти в админ-панель, чтобы удостовериться действительно ли мы подобрали правильные учетные данные.

7) Заходим в админку и смотрим, что там интересного: контент, утилиты, возможности для загрузки файлов. Пример адреса:

http://адрес_машины/скрытая_директория/wp-admin/admin.php?page=adrotate-media

8) Для эксплуатации уязвимости reverse shell нужен PHP-скрипт для взлома.

Возьмите готовый здесь **https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php**

9) Заливайте скрипт на сайт через утилиту **curl** и одновременно запускайте **netcat** на нужном порту, чтобы поймать соединение.

10) Как только попадёте внутрь, идите в директорию WordPress **/var/www/html/wordpress/** и ищете пароль в конфиге базы данных.

11) Логиньтесь и забирайте 1-ый флаг!

Флаг второй:

1) Чтобы найти 2-ой флаг нужно повысить привилегии

CAPTURE THE FLAG

Неплохо было бы попасть на эту машину через SSH под главной учетной записью root. Для доступа к root через SSH узнайте версию ядра командой **uname -a** и ищите эксплойты на **https://www.exploit-db.com**

Загрузите целевую систему эксплойта на атакуемую машину и компилируйте эксплойт:

gcc exp.c -o runexp – компилирование эксплойта

Не забудьте выдать права доступа (**chmod 777 runexp**) на запуск эксплойта и запустить его **./runexp**.

2) После выполнения следующей команды получите корневую оболочку и завершите задание, забрав второй флаг:

cd /root – переход в корневую папу root

/bin/bash – путь к исполняемому файлу Bash в системах Linux

Задание со звёздочкой ☺

Отлично отработали и нашли оба флага? Отлично! Теперь у вашей команды есть шанс взяться за задание повышенной сложности.

Пишите организаторам в телеграмм – они расскажут подробности.